

The Science of Silence: Beyond the Detection Trap

Christopher Frenz

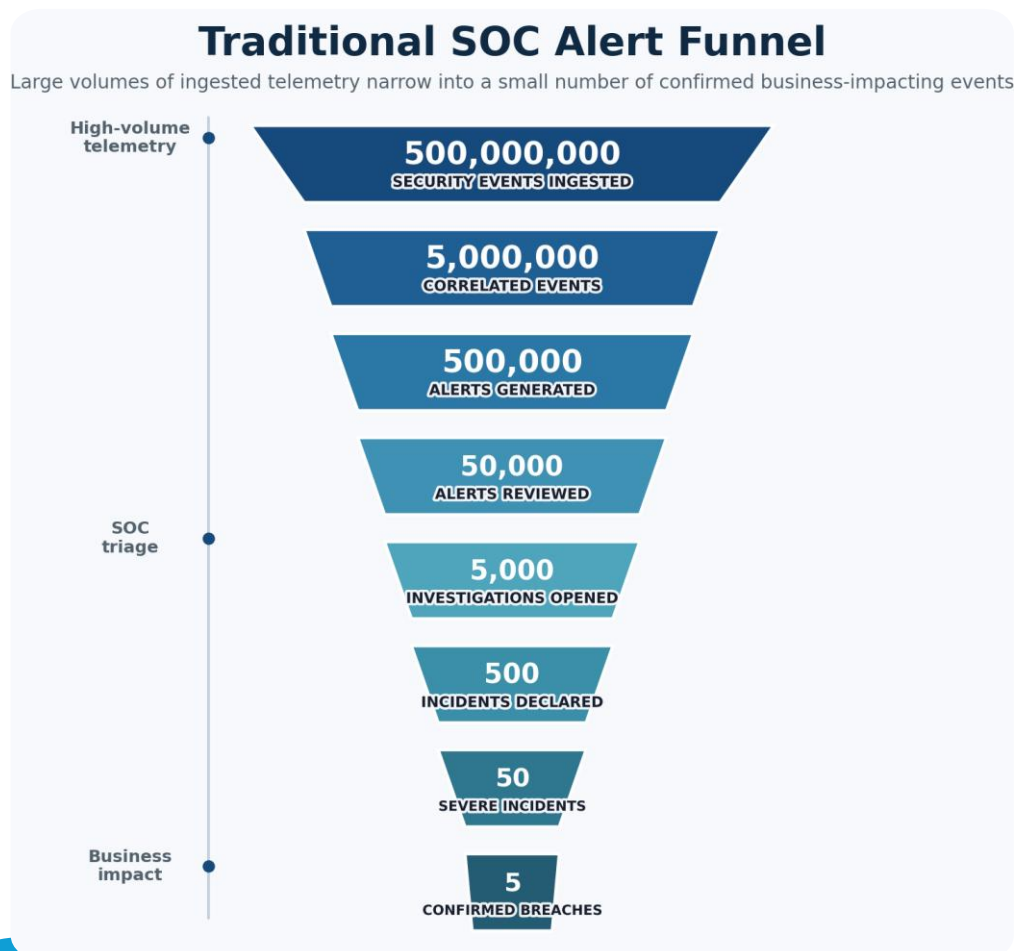


This Started as an Empirical Question in 2015



- May 2016: on this same OWASP NYC stage, I presented a methodology for simulating malware spread to test ransomware defenses
- Precursor to modern day Attack Path Management and Breach and Attack Simulation
- This talk is the 11 year evolution of that idea: from measuring attacker paths to architecturally eliminating attacker optionality
- Subtractive Security formalizes that evolution into an engineering framework
- <https://subtractivesecurity.substack.com/p/cybersecuritys-lost-years-a-decade>

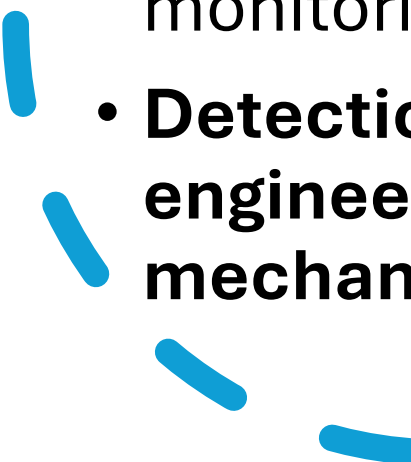
A Testament to Bad Architecture



- High alert volume is not proof of maturity
- It is evidence that too many attack paths still exist
- SOC burnout becomes predictable
- Missed critical alerts become mathematically inevitable
- The organization is compensating with triage instead of architectural constraints
- This is not security. This is architectural debt



From a Reliability Engineering Standpoint

- Objectives are simple and hierarchical
 - **Identify** failure modes.
 - **Eliminate** failure modes.
 - **Constrain** the remaining failure modes.
 - **Monitor** only what physically cannot be eliminated.
 - In cybersecurity we invert the order and skip straight to monitoring, scoring, and building executive dashboards
 - **Detection is not a primary safety mechanism in ANY engineering discipline. It is evidence that primary safety mechanisms have already failed.**
- 

FLAMMABILITY vs FIRE RESPONSE

Stop optimizing for better response. Start engineering out the reasons fires start.

HIGH FLAMMABILITY

Focus on Fire Response (Detection)



Constant Alarms
High volume of alerts



More Detection
More tools, more rules,
more dashboards



More Response
More analysts,
more processes,
more escalation



Burnout & Overload
Teams overwhelmed,
missed critical alerts
become inevitable



High Cost, High Risk
Lots of activity.
Still at high risk.



You can keep responding to fires...
or you can engineer a building that doesn't burn.



LOW FLAMMABILITY

Focus on Fire Prevention (Architecture)



Fire Resistant Design
Secure architecture
by default



Eliminate Attack Paths
Remove combustibles
(vulnerabilities, insecure
configs, legacy risks)



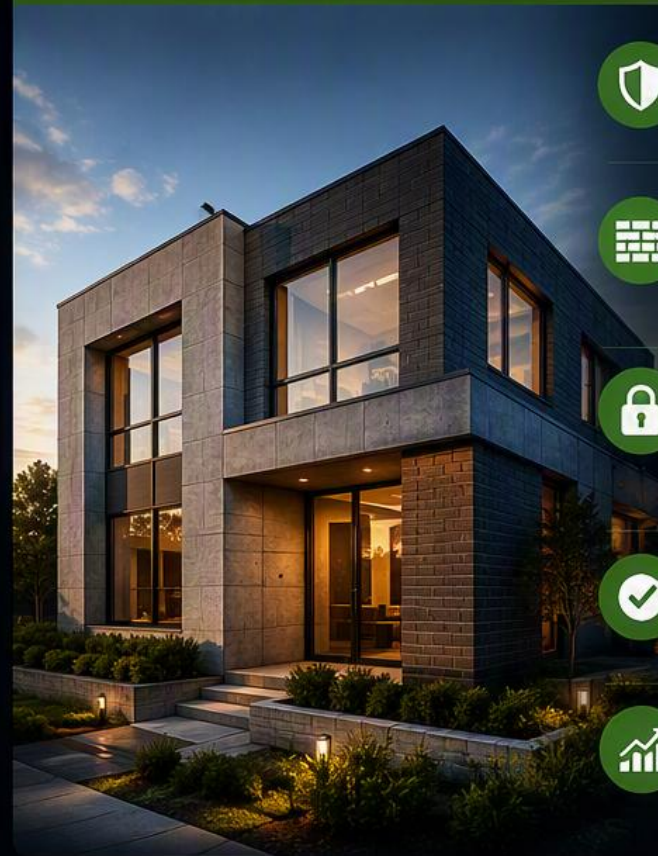
Structural Constraints
Least privilege, segmentation,
strong authentication,
secure defaults



Fewer Fires
Lower alert volume,
higher signal, lower risk



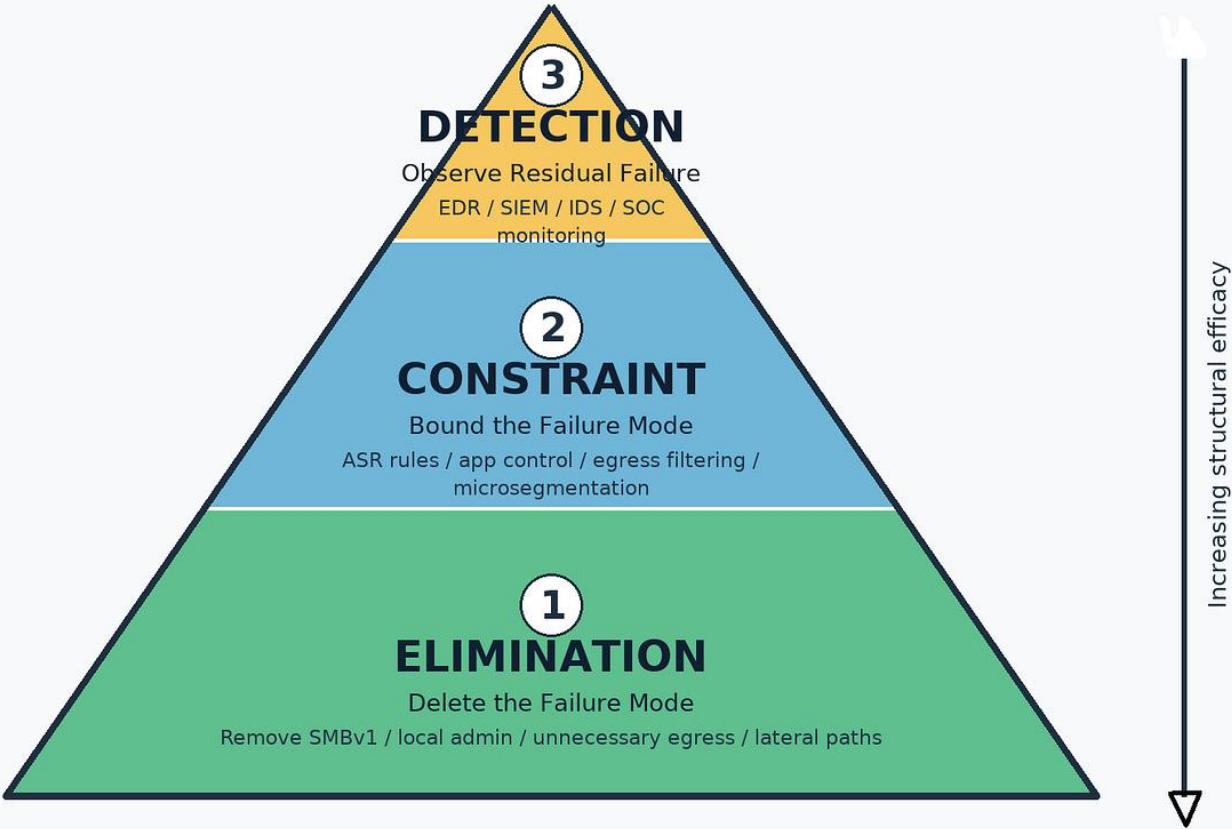
Lower Cost, Lower Risk
Built to be resilient.
Not just reactive.



The attack path is the failure mode.
Reducing attack paths reduces flammability.

The Hierarchy of Efficacy

Mature engineering prioritizes eliminating failure modes before observing residual risk.

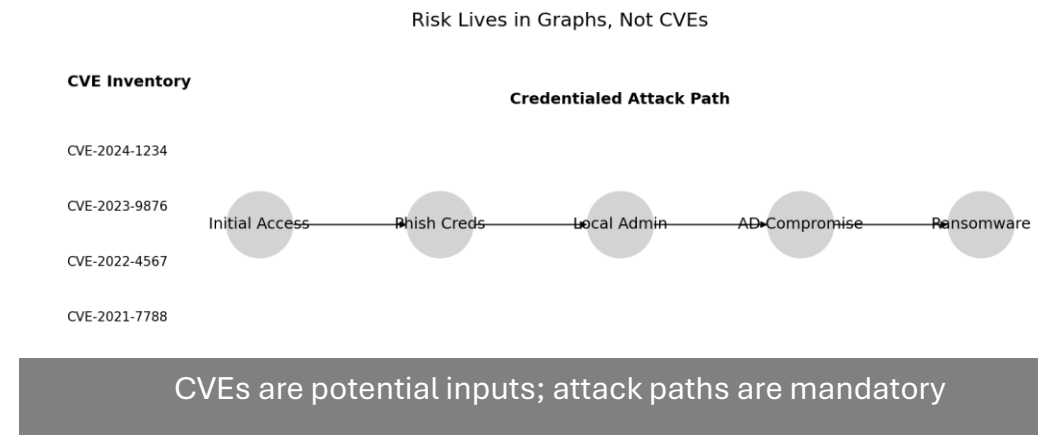


Principle: eliminate first, constrain second, detect only the residual.

Subtractive Security / Science of Silence framework

The Hidden Assumption We've Been Making

- We Act Like Vulnerabilities automatically equal Risk
- But in reality:
 - Vulnerabilities only matter if they can compose into control, movement, or impact
 - A defect without a path is noise
 - Risk lives in graphs, not CVEs



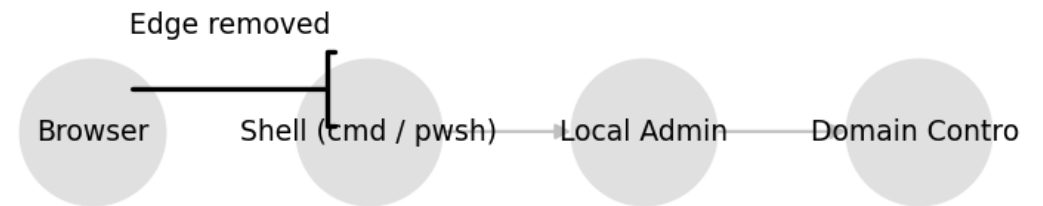
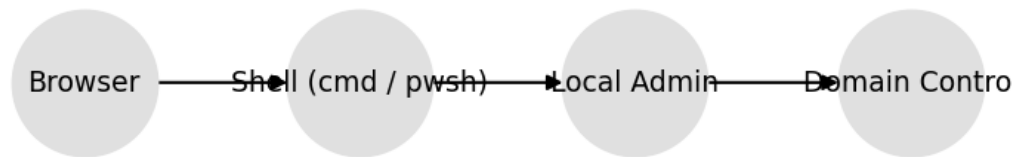
Introducing Path Erasure

- Path Erasure: A Subtractive Model
- Path erasure is the deliberate removal of:
 - Trust relationships
 - Implicit privilege transfers
 - Lateral movement opportunities
 - Exploit chaining surfaces
- For example, there is almost never a legitimate need for a browser to launch a command prompt, Powershell, WMI, etc
- Removing the possibility of this occurring eliminates entire attack paths whether the browser is fully patched or not

Path Erasure Example: Browser → Shell

Before Path Erasure

After Path Erasure



Prevent vulnerabilities from becoming attacks—even when exploited

Code Execution ≠ Lateral Movement

What usually goes wrong

Traditional security assumes:

- Code execution = movement opportunity
- Process execution = pivot
- Shell = network reach

Path erasure example:

Process-level execution constraints

- Prevent user-facing apps (browser, email client, PDF reader) from spawning:
 - shells (cmd, PowerShell, bash, zsh)
 - management tooling (wmic, sc.exe, net.exe)
- Enforce child-process allow-lists
- Enforce per-process network policy (no inbound, no east-west)
- Remove implicit trust between execution context and network movement

Key Insight

Execution is an event. Movement is a privilege.
Path Erasure removed the edge, even if the exploit could not be patched

EVIDENCE-BASED SECURITY FRAMEWORK

A continuous cycle of measurement, simulation, architectural deletion, and validation



Evidence over assumption

Alert output = architectural change

Repeat until paths stay erased

The Null Result

- This is where evidence-based security differs from traditional detection. We are not asking whether the alert fired. We are asking whether the attack step could still happen.
- A successful architectural control does not produce an alert
- A successful path erasure makes the attack step fail to execute
- In evidence-based security, silence is not assumption — it is a tested outcome
- If wscript is blocked because there are no legitimate uses for it, there should never be an alert triggered for wscript again as the trigger conditions are gone
 - No attack path = no more alerts for things formerly on that path

Know Thyself: The Analytics of Command

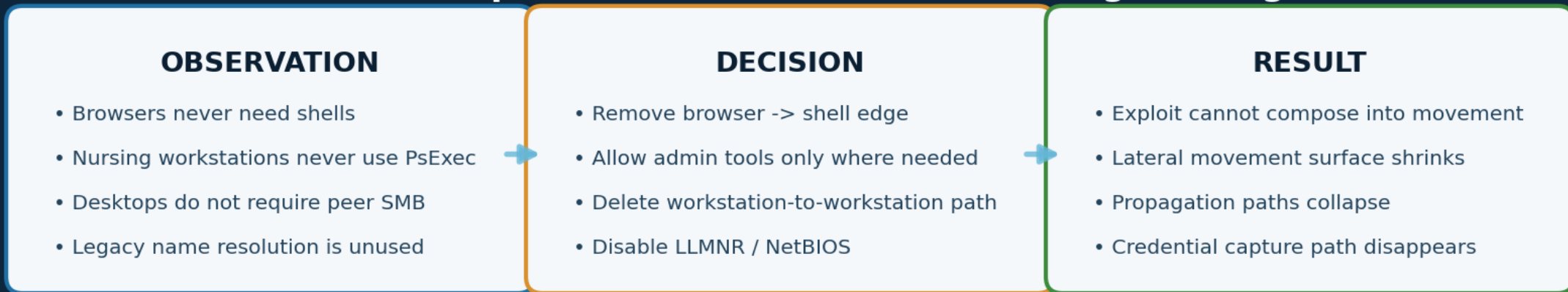
- The question is not what attackers do.
- The question is what your business actually needs to do.
- Measure behavior before restricting behavior
- Identify what is actually used
- Identify who uses it
- Identify where it is used
- Identify which paths are truly authorized
- You cannot subtract what you do not understand.

HOW WE DISCOVER WHAT TO DELETE

Subtraction starts with evidence: observe authorized behavior, then erase what the business does not require



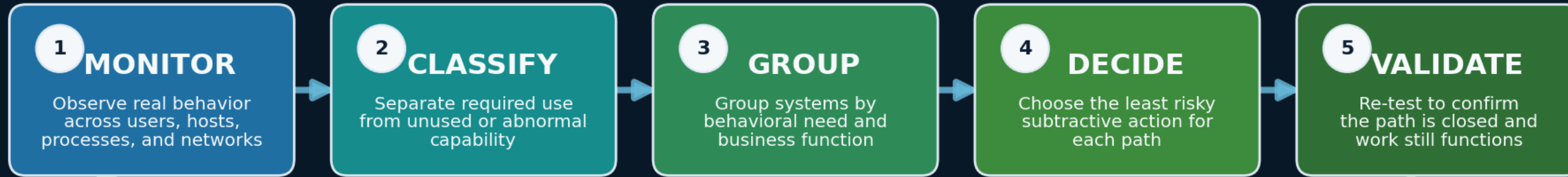
The deletion map converts observations into engineering decisions



You cannot subtract what you do not understand — behavioral analytics tells you what can be safely erased.

BEHAVIORAL MAPPING PROCESS

Use observed authorized behavior to decide what to constrain, isolate, or delete



repeat periodically as the authorized state changes

Behavioral analytics produces a deletion map, not another dashboard

REQUIRED

Keep, but constrain

- Scope by role / host
- Restrict parent-child behavior
- Limit network reach

CONTEXTUAL

Allow only where needed

- Admin tools only on admin hosts
- Scripts only from approved paths
- Egress only to approved destinations

UNNEEDED

Delete the path

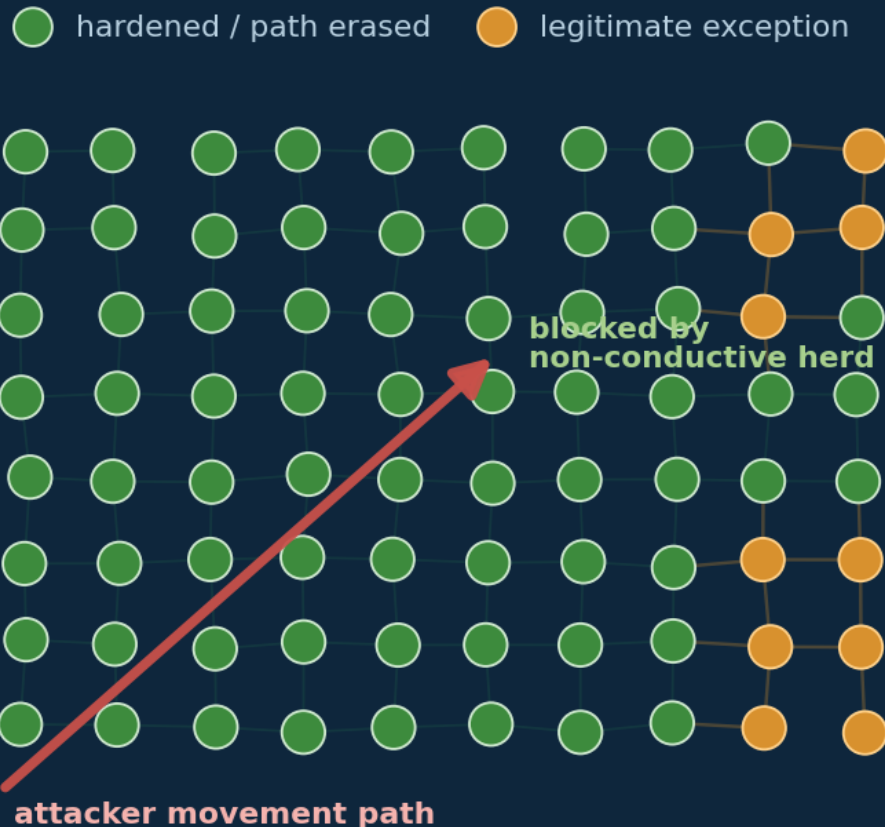
- Block unused interpreters
- Disable legacy protocols
- Remove peer movement paths

The goal is not to block everything — it is to erase every path the business does not require.

CYBER HERD IMMUNITY

Perfect deletion is not required to break the attacker's chain of movement

Hardening enough of the herd breaks conductivity



OLD THINKING

If we cannot block it everywhere, it is not worth blocking anywhere.

SCIENTIFIC THINKING

If we erase the path on most endpoints, the network becomes less conductive.

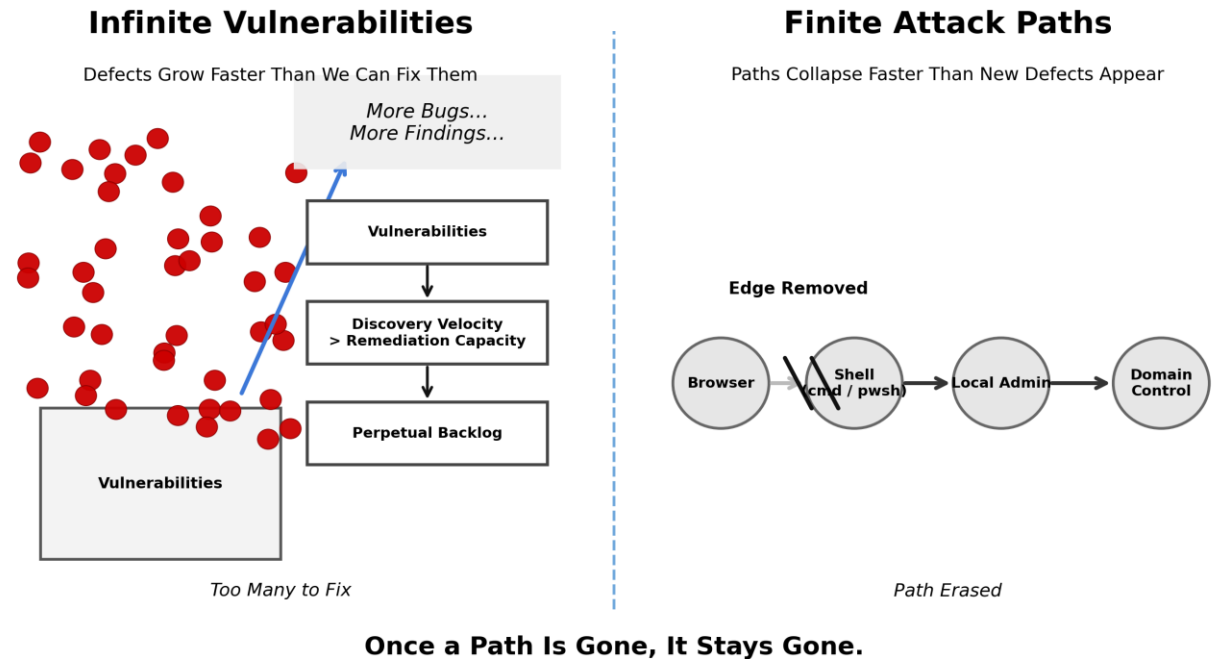
OPERATIONAL RESULT

Attackers are forced into fewer paths that are easier to monitor and validate.

You do not need 100% deletion to reduce risk — you need enough deletion to starve lateral movement.

Why This Scales Better Than “Find & Fix”

- One architectural change can remove thousands of exploit possibilities
- Control efficacy improves even as defect count increases
- Security effort shifts from backlog management to design optimization
- Path erasure works in a world of infinite vulnerabilities. Defects grow faster than we can fix them, but paths collapse faster than new defects appear. Once a path is gone, it stays gone.

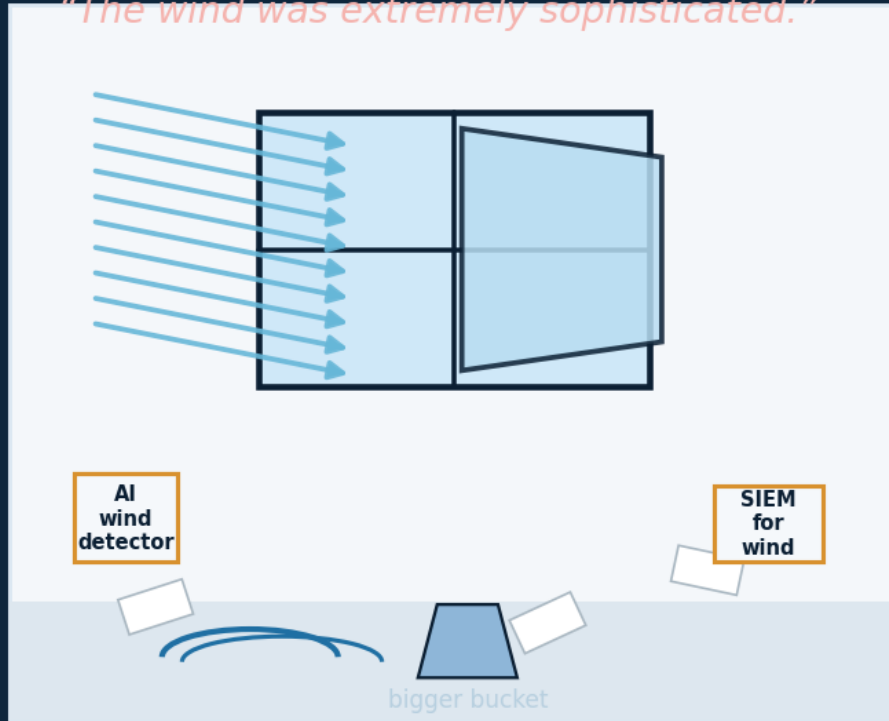


THE VERY SOPHISTICATED WIND FALLACY

When the window is open, blaming the wind is not an engineering explanation.

TRADITIONAL EXPLANATION

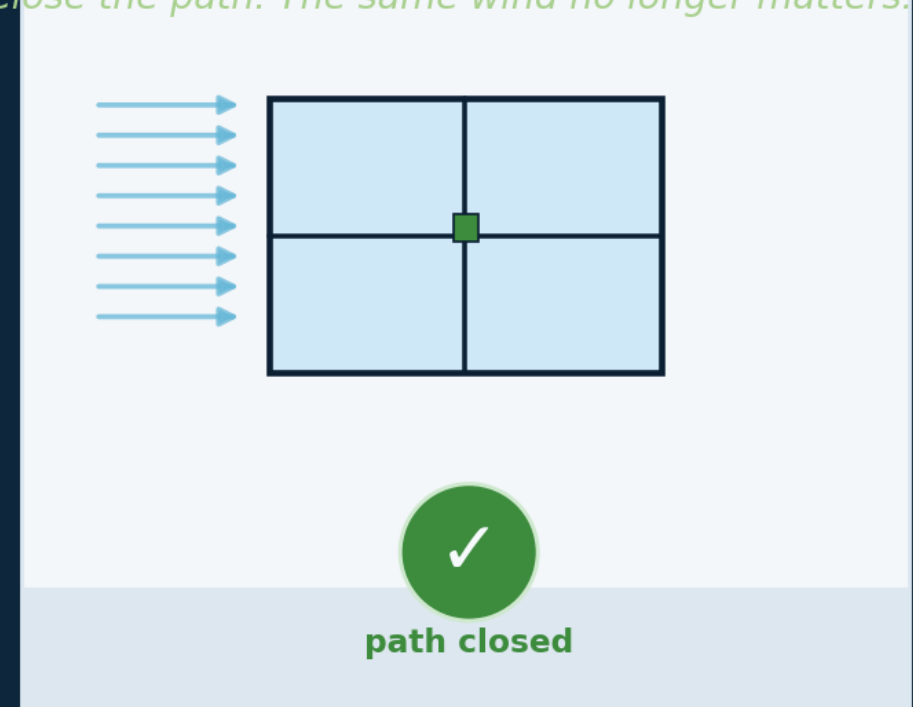
"The wind was extremely sophisticated."



More detectors. More dashboards. Same open path.

SUBTRACTIVE EXPLANATION

Close the path. The same wind no longer matters.



Same storm. Closed window. No incident.

Attackers are not magicians — they execute mundane steps through paths we left open.

WHAT ABOUT ZERO-DAYS?

The exploit may be unknown. The paths it must travel are often knowable.

TRADITIONAL THINKING

Unknown vulnerability = unknown risk



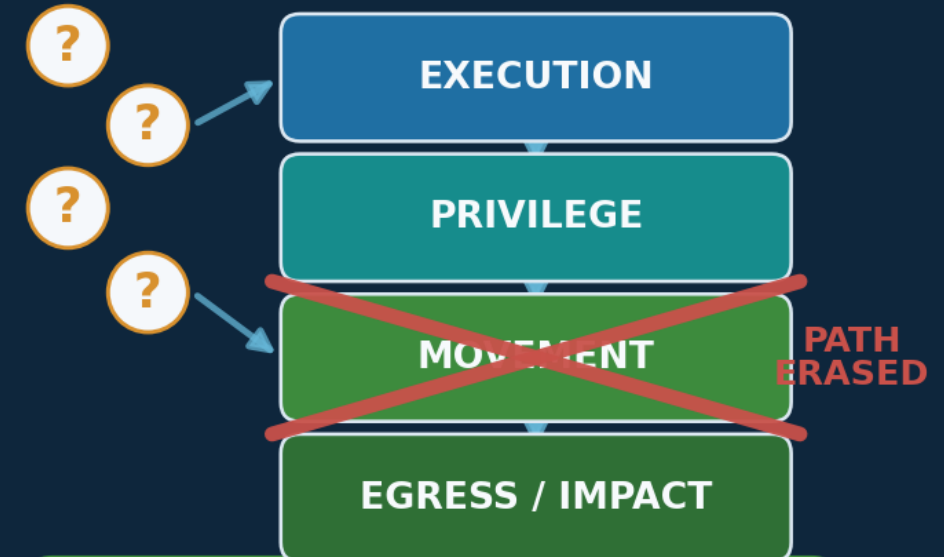
Need better detection

react after the unknown
produces observable activity

VS

SCIENCE OF SILENCE

Unknown exploit still needs known paths

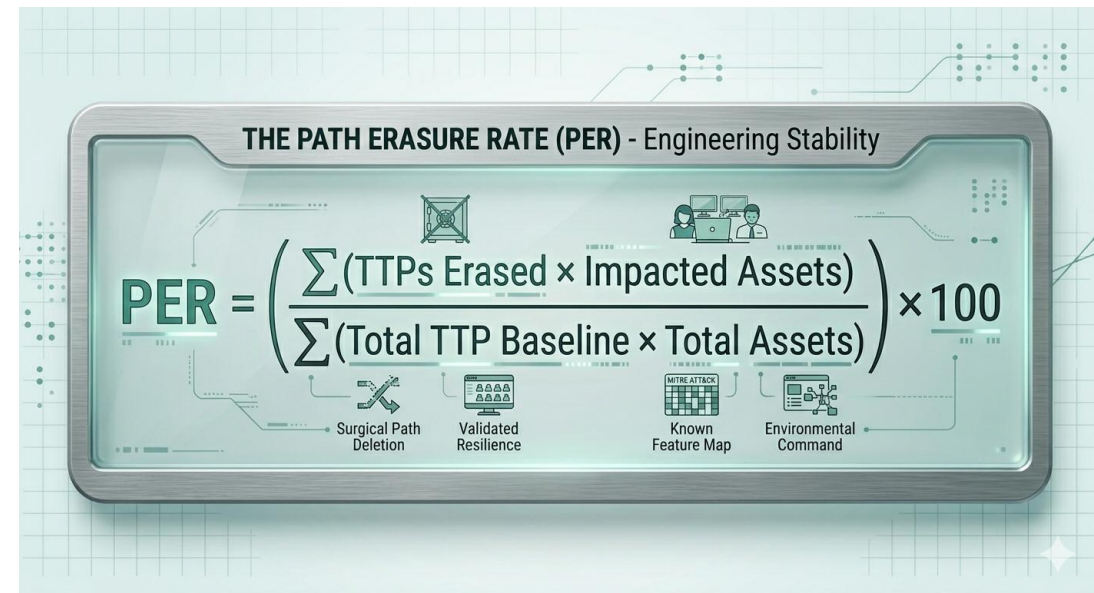


Path cannot reach impact

We do not need to know tomorrow's exploit. We need to know today's attack paths.

Path Erasure Rate (PER): Measuring Real Risk Reduction

- What PER Measures
 - Structural risk removal
 - Reduction in attacker optionality
 - Architectural efficacy — not activity
- What PER Ignores
 - CVE counts
 - Patch velocity
 - Alert volume
- A leading metric, not a lagging one
- Progress is fewer reachable paths, not fewer CVE findings
- PER does not require perfect enumeration — it tracks relative collapse of reachable paths over time.

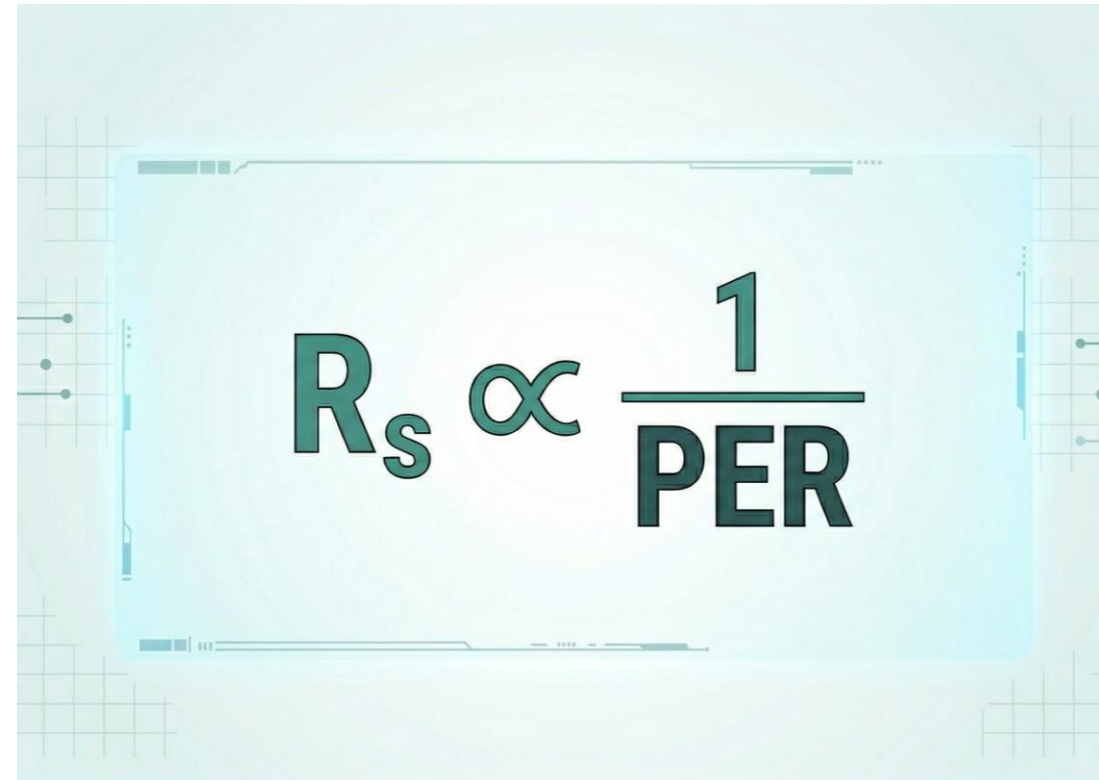


Full engineering specification:

[Path-Erase-Engine/PER-1.0_Engineering_Specification.md](#) at main · cfrenz/Path-Erase-Engine

The Law of Subtractive Risk

- Law
 - Security improves fastest by removing attack paths,
 - not by adding reactive controls.
- Implications
 - Additive security increases complexity and failure modes
 - Subtractive security reduces system degrees of freedom
 - Fewer paths beats faster reaction
- Conclusion
 - The quietest environments are the safest
 - Silence is verified evidence, not neglect


$$R_s \propto \frac{1}{\text{PER}}$$

The Science of Silence

- We do not measure security by:
 - alerts
 - dashboards
 - investigations
 - activity
- We measure security by:
 - the attacker actions that are no longer possible

PATH ERASURE: FEWER ROADS. STRONGER SECURITY.

BEFORE PATH ERASURE

Too many roads. Too many ways in.



IMPOSSIBLE TO MONITOR.

Hundreds of potential paths.
Attackers only need one.

AFTER PATH ERASURE

Fewer roads. Fewer risks. Stronger security.



POSSIBLE TO PROTECT.

Only a handful of controlled paths.
Stronger security with less to defend.



WE DON'T TRY TO WATCH EVERY ROAD.
WE REMOVE ROADS.

Every road removed is a threat that no longer requires monitoring, alerting, investigation, or response.

Additional Resources

- The Science of Silence – Available in Bookstores
- The Subtractive Security Substack - <https://subtractivesecurity.substack.com/>
- OWASP Subtractive Top 10 - [OWASP/OWASP-Subtractive-Hardening-Top-10](#)
- The Subtractive Security Path Erasure Engine (example path erasures for endpoints) - [cfrenz/Path-Erasure-Engine: Subtractive Security Path Erasure Engine](#)
- Governance/Policies <https://subtractivesecurity.com/Guidance/>